

Confidential

ACME Corporation Technologies Incident Analysis & Response Report

Prepared by:

Christian DuBois – Senior Cybersecurity Analyst

Date:

August 15, 2025

Classification:

Confidential

Note:

This document contains sensitive company information. Access is limited to authorized employees only.

Confidential

Executive Summary

On Tuesday, August 12, 2025, ACME Corporation Technologies experienced a cybersecurity incident that originated through a phishing email sent to a finance employee. This phishing email contained a malicious document, which was opened by the employee. Once this file was opened, the attacker was able to gain access to internal systems using stolen credentials. The attacker then moved through the network and accessed a server containing sensitive information.

Sensitive patient information was encrypted and exfiltrated to an external location. While the exact effect is unknown, it is clear that large amounts of sensitive information, including protected healthcare information, were stolen by the attacker.

This incident was primarily caused by a successful phishing attempt, but multiple gaps in security controls allowed the attacker to move freely within the network and avoid detection. The security-related issues allowed the attacker to access systems containing highly sensitive information.

There was a delay of several hours between the initial detection of suspicious activity and the start of post-incident containment activities. This gap in time allowed the attacker to move around the internal network.

Conclusion: The attacker was able to access the company network by stealing credentials via a phishing email. The attacker was able to move laterally through the network due to security weaknesses. Sensitive patient information that falls under HIPPA regulation was stolen. Containment activities have been started, and investigation continues to determine the full extent of the security breach.

Confidential

Scope, Constraints & Assumptions

Scope:

This Incident Analysis and Response Report follows the systems listed in the SOC summary, including the Internal Host (FIN-WKS-12), rdp-gw1, rdp-host04, and the compromised server (health-srv-03).

Constraints:

This report is limited to the information given, there is no access to full forensic artifacts for in-depth research on exact methodologies used by the attacker, and there is not a network diagram of the affected company.

Assumptions:

Additional systems may have been compromised but not found at this time. Current information does not suggest the possibility of an insider acting on behalf of the attacker.

Methodology & Evidence Sources

Methodology:

This investigation dives into the information listed in the SOC Incident Summary, Indicators of Compromise (IoCs), utilizing the NIST and MITRE Framework to accurately portray the attack. Following both frameworks, how the attack happened, and what failed will be clear.

Evidence Sources:

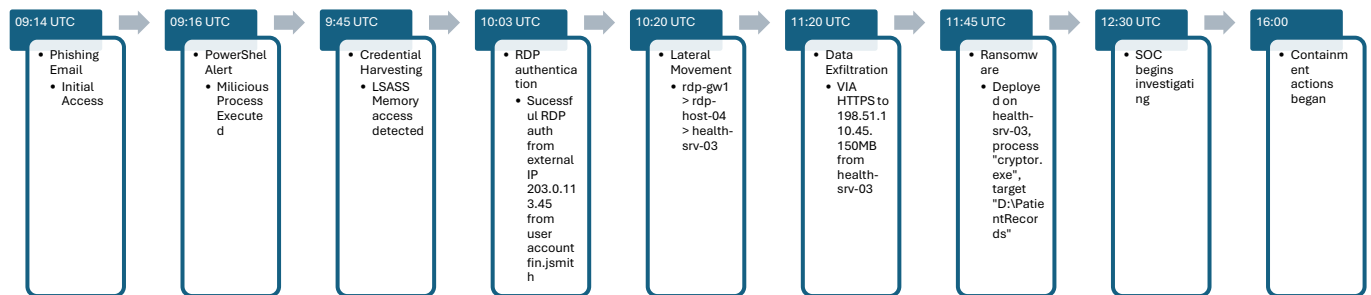
The attack timeline (more information regarding this on the next page), listed Indicators of Compromise, and the additional forensic information will be examined. Evidence will be examined with the cause in mind. Technical, human, and process errors will be investigated to fully understand the origin/scope of the attack.

However, since a full-scale investigation has not been completed, some information that could be useful is not available yet. This gap in evidence could potentially include email headers, memory dumps, and packet capture data.

Confidential

Timeline & Attack Chain Visualization

The timeline shows how the attack progressed from the delivery of a phishing email to ransomware deployment and delayed response activities. Based on the evidence below, the attacker moved through multiple stages of escalation in a short time and was able to maintain persistence for several hours before initial response began.



This timeline shows how attacker moved from phishing to credential theft and remote access authorization within an hour. By 11:45 UTC, sensitive patient data was exfiltrated and ransomware was deployed, which encrypted files on the healthcare server. Suspicious PowerShell activity was detected at 09:16 UTC, but due to misconfigured alert levels the SOC didn't begin investigating until 12:30 UTC. Containment actions did not begin until 16:00 UTC, which gave the attacker more than enough time to carry out each phase of the attack with no resistance.

Confidential

Technical Findings

The evidence listed shows that a malicious file was delivered to an employee through a phishing email. Once this file was opened, the macro executed malicious code through PowerShell. It appears that user credentials were harvested shortly after the malicious processes were ran. These user credentials were then used by the attacker to access the remote gateway server and move laterally into the healthcare server. The report also indicates persistence was maintained by a Windows Run process (HKLM\Software\Microsoft\Windows\CurrentVersion\Run\AcmePersist), scheduled task (\Microsoft\Windows\WDI\AcmeUpdate), and a malicious service (AcmeSystemService). The service was responsible for exfiltrating data to the attackers C2 listener in 5 minute intervals. The final confirmed impact is ransomware execution on the health-srv-03. The attacker relied on stolen credentials and multiple weak internal security controls escalate from a finance workstation to a healthcare server which contains sensitive patient information.

Root Cause Analysis

Technical root causes include:

- Failure to quarantine the phishing email which contained a malicious file
- Insecure access control configurations
- Lack of network segmentation
- EDR alerts misconfigured

The delay in containment activities is directly tied to the EDR alerts not being properly configured. The malicious activity was marked as “low priority” which allowed the attacker to maintain persistence and exfiltrate data with no response from the security team until hours later. These security weaknesses are inconsistent with NIST recommendations on cybersecurity protection, detection, and response. Ultimately, the incident occurred due to multiple layers of defense that either failed or were not properly configured, not because of a single issue.

Confidential

Kill Chain Disruption Opportunities

The best time to stop this attack was at 09:16 UTC when the finance workstations (FIN-WKS-12) initiated the PowerShell process and the EDR flagged this as suspicious activity. When this was detected, the system should've immediately been isolated from the network, and the PowerShell process should've been terminated. The compromised user account (fin.jsmith) should've been temporarily disabled with AD to prevent the attacker from using the compromised user credentials. If these steps were taken upon detection of suspicious activity, the later use of compromised credentials, unauthorized RDP access, lateral movement, exfiltration of data, and persistence may have been prevented. Also, when LSASS memory access was detected at 09:45 UTC there should have been efforts to recover. This is a clear indicator of credential theft, which should have triggered escalation to incident response individuals, and containment of any systems that could be accessed by the compromised user account. Another disruption option occurred at 10:03 UTC, when an external IP address eventually authenticated with the rdp-gw1 server after 47 failed connection attempts. This is a clear indicator of unauthorized access which should have been flagged and investigated immediately. The lateral movement between rdp-gw1 to rdp-host-04 that occurred after should have been addressed as well. This movement shows that network segmentation controls were either not in place or failed entirely. The clearest opportunity to stop this attack in its tracks was the failure to act on the initial EDR alert, because stopping the attack at this stage would have prevented any further persistence.

Confidential

MITRE Kill Chain / IoC's

MITRE Phase	Attack Observed	Disruption	Control Type	Implementation
Initial Access	2025-08-12 09:14:02 UTC - Phishing email delivered to finance.team@acme-corp.internal; Attachment: Invoice_Q3_2025.xlsm	Best way to stop the attack would've been blocking the malicious email before it reached the users email inbox.	Preventative	M36 Safe Attachments, attachment isolation, macro-enabled blocking on attachments, conducting regular phishing tests.
Execution	2025-08-12 09:15:30 UTC - User fin.jsmith opens malicious XLSM; Workbook_Open macro executes silently	Controls should've prevented macros from running. Office365 applications shouldn't be able to create processes.	Preventative	Office macros disabled, application control, standard user accounts shouldn't be able to run unknown processes at admin-level access.
Execution	2025-08-12 09:16:15 UTC - Endpoint FIN-WKS-12 (192.168.10.42) spawns: powershell.exe - EncodedCommand [base64_payload]; EDR flags suspicious PowerShell execution	The workstation should've been isolated immediately, the process should've been killed, and the user account should've been disabled.	Detective/Corrective	EDR automation, script blocking, incident response playbooks.

Confidential

Credential Access	2025-08-12 09:45:00 UTC - Credential harvesting begins (LSASS memory access detected)	This should've resulted in escalation because its obvious credential theft.	Corrective	LSASS protection, password resets.
Command and Control	2025-08-12 10:03:12 UTC - Successful RDP authentication from external IP 203.0.113.45; Target: rdp-gw1 Account: fin.jsmith EventID: 4624	Clear unauthorized remote access that should've been blocked.	Detective	MFA, account lockout thresholds, IP restrictions, firewall rules.
Lateral Movement	2025-08-12 10:20:00 UTC - Lateral movement chain initiated: rdp-gw1 → rdp-host-04 → health-srv-03	Proper network segmentation could've prevented the attacker from moving laterally.	Preventive/Corrective	Network segmentation, firewall rules, server access controls, least privilege
Exfiltration	2025-08-12 11:20:07 UTC - Data exfiltration via HTTPS POST to 198.51.100.45; SNI: exfil-example.test Volume: ~150MB; Origin: health-srv-03 (10.50.3.11)	Outbound HTTPS transfers to an unknown external IP address should be prevented automatically.	Preventive	Firewall rules, TLS inspection, DLP configuring.
Impact	2025-08-12 11:45:30 UTC - Ransomware deployment on health-srv-03; Process: cryptor.exe Target: D:\PatientRecords\;	If the attack was contained the attacker never would've been able to	Preventative/Corrective	EDR ransomware monitoring/containment, host isolation, sanitization.

Confidential

	Extension: .LOCKED_ACME2 025	install malware.		
Detection	2025-08-12 12:30:00 UTC - SOC begins investigation (3+ hours post- compromise)	The delayed response allowed the attacker to complete their objective.	Detective	Alert optimization, automated alert responses, SOC escalation.
Containment	2025-08-12 16:00:00 UTC - Containment actions initiated	Should've been earlier.	Corrective	Incident response playbooks, policies/procedures, SLA, Alert optimization

Confidential

Business Impact Assessment

This security incident had a direct operational impact because ransomware was deployed on the health-srv-03, and patient information located in the *PatientRecords* file share were exfiltrated and encrypted. The encryption of patient healthcare records most definitely had an impact on normal operations that were executed/processed by that server. Due to the nature of ACME's work, it is important to consider the potential implications of sensitive patient data being exposed. This incident may trigger compliance actions that are required under the HIPPA Security Rule and PCI DSS depending on the confirmed scope of the breach. Impacts may include financial settlements/fees, incident response services, legal review, notifying individuals whose data may be exposed, and further investigation regarding negligence. The incident may create operational disruption, regulatory investigations, legal issues, and reputational damage.

Remediation Roadmap

It is crucial that all affected systems are stabilized to ensure that no malicious artifacts remain active. Compromised credentials should be addressed, affected systems should be isolated/sanitized, RDP access controls need to be implemented, and all IoC's should be investigated further. Short term, ACME should implement proper network segmentation between corporate and healthcare systems alike, EDR alerts need to be properly configured to ensure "high-risk" activities are detected immediately, and all malicious processes should be removed entirely. Long term, ACME needs to strengthen remote access policies, improve the current monitoring system, isolate backups, and carry out regular security awareness training for all employees. These remediation activities align directly with the NIST Cybersecurity Framework and CIS controls, which place a strong emphasis on layered defense, access control optimization, proper monitoring, alerting, and containment protocols.

Confidential

Detection Engineering Recommendations

Detection engineering should place a focus on catching suspicious activity before it results in a larger-scale incident. “Non-human” activities should be immediately flagged as high-risk alerts and should be investigated immediately. For example, an Office365 application spawning a PowerShell process with root-level access should be immediately flagged. Authentication monitoring should be correlating failed login attempts with successful attempts. Network monitoring should flag large outbound HTTPS transfers to external/unknown IP addresses. EDR systems should flag processes that are commonly associated with malicious processes. The best detection processes are those which analyze behavior that is unlike normal baseline activity.

Communications Plan

Communication within the organization should be clear, and easy for leadership to follow. Employees should be made aware of the cybersecurity incident, and employees should understand that the investigation is still in progress. Employees should be directed to report any suspicious activity to the IT help desk, or the IT security team. I would recommend resetting all company passwords for all employees, these instructions should be communicated company wide. Employees should consult their direct manager with any questions, and the manager should replay these questions to the appropriate security professional. Any customer or patient that may have been affected by this data breach should be properly informed with information regarding what PII is exposed, what the company is doing in response, and what steps should be taken. All regulatory compliance communications should be contained within the legal, security, and management teams. Public announcements should be short and concise, with an emphasis on what ACME is doing in response to this breach. The biggest risk with an incident of this nature is unclear and inconsistent information. It is of utmost importance that all information is communicated clearly and correctly to all individuals that need to be aware of what occurred.

Confidential

Post-Incident Strategic Improvements

ACME should look at this incident through the lens that real change needs to be carried out. This is not an incident that occurs once, gets contained, and never happens again. This event clearly shows that warning signs were present, but the organization was not prepared to respond. Strategic improvements should include an emphasis on quicker response and escalation of security alerts, stronger network segmentation controls, proper access control policies, and better isolation of critical systems from normal user devices. Backups should be completely isolated from any production servers to ensure the integrity, availability, and authenticity of said backups. ACME needs to address the current alerting systems approach on alert fatigue, because the evidence clearly shows that high-risk alerts were looked over in a way that increased risk to the business. Ultimately, ACME needs to make changes to ensure a successful phishing attempt doesn't result in complete data breach.

Confidential

References

National Institute of Standards and Technology. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST SP 800-61 Rev. 3). <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

Center for Internet Security. (2024). *CIS Critical Security Controls v8.1*. <https://www.cisecurity.org/controls/v8-1>

MITRE Corporation. (n.d.). *MITRE ATT&CK®*. <https://attack.mitre.org/>